SURVEY

You are being invited to participate, as a volunteer, in the research "Characterization of Software Security Practices and Automated Tools" conducted by UFC and the University of Notre Dame.

This research aims to explore the characterization of software security practices commonly used by developers. We are also interested in understanding how developers handle the use of automated security tools. By exploring these objectives, we hope to be able to provide valuable insights into different software security practices, as well as factors related to the adoption of automated security tools.

To participate in this study, you must be at least 18 years old and have experience in the field of software development or information security. Your participation consists of completing an online questionnaire about software security practices and automated security tools, which will take approximately 15 minutes. We assure you that all information provided will be kept confidential and secure.

The Free and Informed Consent Form (TCLE) is available at the following link and outlines your rights as a participant. We encourage you to review it carefully to fully understand the purpose and scope of the study. Participation is entirely voluntary, and you are free to decline or withdraw your consent at any time, without any penalties or negative consequences.

After having received clarifications about the nature of the research, its objectives, and methods, I declare that I am over 18 years old and agree to participate by completing the participation form, in accordance with the provisions of the General Data Protection Law (Law No. 13,709/2018). In case of a negative response, the form will be closed, thus ensuring respect for the participants' autonomy and privacy, as established by current legislation.

( ) I agree to participate.
( ) I do not agree to participate.

GENERAL CHARACTERIZATION OF THE PARTICIPANT

In this section, we will collect basic information and personal data to better understand your profile.

1) **How old are you? (Mandatory)**
   ( ) 18-24 years old
   ( ) 25-34 years old
   ( ) 35-44 years old
   ( ) 45-54 years old
   ( ) 55-64 years old
   ( ) 65 years or older.
   ( ) I prefer not to say.

2) **In which Brazilian state do you currently live? (Mandatory)**
   ( ) Acre (CA)
   ( ) Alagoas (AL)
   ( ) Amapá (AP)
   ( ) Amazonas (AM)
   ( ) Bahia (BA)
   ( ) Ceará (CE)
   ( ) Distrito Federal (DF)
   ( ) Espírito Santo (ES)
   ( ) Goiás (GO)
   ( ) Maranhão (MA)
   ( ) Mato Grosso (MT)
   ( ) Mato Grosso do Sul (MS)
   ( ) Minas Gerais (MG)
   ( ) Pará (PA)
   ( ) Paraíba (PB)
   ( ) Paraná (PR)
   ( ) Pernambuco (PE)
   ( ) Piauí (PI)
   ( ) Rio de Janeiro (RJ)
   ( ) Rio Grande do Norte (RN)
   ( ) Rio Grande do Sul (RS)
   ( ) Rondônia (RO)
   ( ) Roraima (RR)
   ( ) Santa Catarina (SC)
   ( ) São Paulo (SP)
   ( ) Sergipe (SE)
   ( ) Tocantins (TO)
   ( ) Outside the country

3) **What is your gender? (Mandatory)**
   ( ) Man
   ( ) Woman
   ( ) Non-binary, genderqueer, or gender non-conforming
   ( ) Prefer not to say
   ( ) Others

4) **What is your highest level of completed education? (please select one) (Mandatory)**
   ( ) High School
   ( ) Bachelor's degree (B.A., B.S., B.Eng., etc.)
   ( ) Specialization
   ( ) Master's degree (M.A., M.S., M.Eng., MBA, etc.)

( ) PhD student

5) **What is your work model? (please select one) (Mandatory)**
( ) Remote
( ) Hybrid
( ) In-person

6) **Which role best describes your current position in software development projects? (Mandatory)**
[ ] Cryptographer
[ ] Data Scientist
[ ] Developer (Backend, frontend, fullstack)
[ ] DevOps engineer
[ ] Penetration tester
[ ] Privacy engineer
[ ] Product owner
[ ] Project Lead / Project Manager
[ ] Requirements Engineer
[ ] Security engineer
[ ] Solution Architect
[ ] Test Manager / Tester
[ ] UX/UI designer
[ ] Others:_____

7) **Please, indicate the seniority level of the position you hold. (please select one) (Mandatory)**
( ) Intern/Trainee
( ) Junior (up to 5 years)
( ) Mid-Level (6 to 9 years)
( ) Senior (10+ years)

8) **How many years of experience do you have in roles related to software development or IT? (Mandatory)**
( ) Less than 1 year
( ) Between 1 and 3 years
( ) Between 4 and 6 years
( ) Between 7 and 14 years
( ) More than 15 years

9) **How many years of experience do you have in roles related to Software Security? (Mandatory)**
( ) None
( ) Less than 1 year
( ) Between 1 and 3 years

( ) Between 4 and 6 years
( ) Between 7 and 14 years
( ) More than 15 years

10) What types of systems do you currently work with? (multiple choices allowed) (Mandatory)

[ ] Embedded applications
[ ] Operating Systems
[ ] Desktop applications
[ ] Web applications
[ ] Mobile applications
[ ] Developer tools
[ ] Middleware
[ ] Others

11) What are the domains of the systems you currently work with? (multiple choices allowed) (Mandatory)

[ ] Banking/Financial
[ ] Defense & Security
[ ] Education
[ ] Embedded systems in Automotive or Avionics
[ ] Entertainment
[ ] Healthcare
[ ] Insurance
[ ] Logistics
[ ] Oil & Gas
[ ] Sales/E-commerce
[ ] Telecommunication
[ ] Others:_____

12) What is the sector of the organization you currently work for? (please select one) (Mandatory)

( ) Self-employed
( ) Private sector
( ) Public sector
( ) Startup
( ) Non-profit organization
( ) Non-governmental organization
( ) Research and development projects.
( ) Others:_____

13) What is the size of the company that you currently work for? (please select one) (Mandatory)

( ) Up to 9 employees

( ) From 10 to 49 employees
( ) From 50 to 99 employees
( ) From 100 to 499 employees
( ) From 500 to 999 employees
( ) More than 1000 employees
( ) I don't know

CHARACTERIZATION OF EXPERIENCE WITH SOFTWARE SECURITY

In this section, we would like to know your experience working in software security.

14) **Do you have (or have you had) any work experience related to software security in the software development process? (please select one) (Mandatory)**
( ) I have worked (or currently work) with security in the software development process.
( ) My development group/team works (or has worked) with security, but I am not directly involved in any tasks.
( ) I have never had direct or indirect experience with security in the software development process.

15) **Do you have any certifications in the area of information security? If so, what are they? If you do not have one, select the option "I do not have any certification." (multiple choices allowed) (Mandatory)**
[ ] Certified Information Systems Security Professional (CISSP)
[ ] Certified Information Security Manager (CISM)
[ ] Certified Information Systems Auditor (CISA)
[ ] Certified Ethical Hacker (CEH)
[ ] CompTIA Security+
[ ] Certified Cloud Security Professional (CCSP)
[ ] Offensive Security Certified Professional (OSCP)
[ ] GIAC Security Essentials (GSEC)
[ ] Certified Incident Handler (GCIH)
[ ] Certified Information Privacy Professional (CIPP)
[ ] I do not have any certification
[ ] Others:_____

16) **Please briefly describe your experience with software security. If not applicable, please respond that you have no experience (Mandatory)**
_____
_____

CHARACTERIZATION OF SOFTWARE SECURITY PRACTICES

In this section, we will address some software security practices that are used during the software development process and collect your perception about these practices.

To answer the next questions, consider describing the following software security practices:

- **Code Reviews:** Manually or automatically analyze code and/or code changes (commits) to identify security flaws, violations to secure coding standards and mitigate identified vulnerabilities.
- **Threat Modeling:** Identify threats, and then define countermeasures to prevent, or mitigate the effects of, threats to the system.
- **Identifying Abuse/Misuse Cases:** Identify potential abuse or misuse scenarios that could lead to security vulnerabilities.
- **Architectural Risk Analysis:** Assessing and reviewing the software architecture to identify potential security risks and mitigate them before they become vulnerabilities.
- **Penetration Testing:** Utilizing specialized tools to simulate attacks on the application, helping to identify and address security weaknesses.
- **Risk Management**: Define the main objectives and assess the criticality of the application to prioritize security efforts. Assess the potential impact of security breaches on business operations to guide security priorities.
- **Vulnerability Management:** Continuously identifying, assessing, and mitigating security vulnerabilities throughout the application's lifecycle.
- **Manual/Automated Security Testing:** Creating and executing test cases that specifically focus on assessing the security aspects of the application.
- **Performing Fuzz Testing:** Using fuzz testing techniques to introduce unexpected inputs into the application to identify vulnerabilities that could lead to security issues.
- **Security Requirements Engineering:** Identify and analyze security needs based on potential threats, regulatory requirements, and business goals as well as specify security measures and protocols to be implemented by the system.
- **Secure Coding:** Follow secure coding standards to minimize vulnerabilities in the code, such as deprecating unsafe functions, using strong hashing algorithms, etc.
- **Emergency Codebase Response:** Respond quickly to and patch security vulnerabilities in the codebase to prevent exploitation.
- **Security Configurations & Management:** Ensuring that systems, applications, and networks are configured to meet security requirements and minimize vulnerabilities. Regularly verify that security configurations are properly applied and maintained.
- **Monitoring for Security Events:** Using automated tools and processes to continuously monitor for security events and detect potential threats in real-time.
- **Undergoing External Security Audits:** Engaging independent third-party auditors to assess the application's security and recommend improvements.
- **Software Supply Chain Security:** Identify vulnerabilities in reused 3rd party software/libraries/APIs and addressing/patching vulnerabilities in them. Publish and consume the Software Bill of Materials (SBOM).

17) **How often do you apply the following software security practices in your projects? Consider marking "Not Applicable" for practices you do not use. (Mandatory)**

Practice	**Daily**	**Weekly**	**Monthly**	**Annually**	**Not applicable**
Code Reviews					
Threat Modeling					
Identifying Abuse/Misuse Cases					
Architectural Risk Analysis					
Penetration Testing					
Risk Management					
Vulnerability Management					
Manual/Automated Security Testing					
Performing Fuzz Testing					
Security Requirements Engineering					
Secure Coding					
Emergency Codebase Response					
Security Configurations & Management					
Monitoring for Security Events					
Undergoing External Security Audits					
Software Supply Chain Security					

18) **Do you apply any other software security practices beyond those mentioned above? If so, please briefly describe these practices. (Optional)**

_____

_____

19) **How have you implemented the aforementioned software security practices in your projects? (Mandatory)**

_____

_____

20) **Based on your experience, how would you characterize the ease of use of the following software security practices? Consider marking "Not Applicable" for practices you do not use. (Mandatory)**

Practice	**Very Low**	**Low**	**Moderate**	**High**	**Very High**	**Not applicable**
Code Reviews						
Threat Modeling						
Identifying Abuse/Misuse Cases						
Architectural Risk Analysis						
Penetration Testing						
Risk Management						
Vulnerability Management						
Manual/Automated Security Testing						
Performing Fuzz Testing						
Security Requirements Engineering						
Secure Coding						
Emergency Codebase Response						
Security Configurations & Management						
Monitoring for Security Events						

Undergoing External Security Audits						
Software Supply Chain Security						

21) Based on your experience, how do you evaluate the \textit{effectiveness} of the following software security practices in preventing, removing, or detecting security issues in your projects? Consider marking "Not Applicable" for practices you do not use. (Mandatory)

Practice	**Very Low**	**Low**	**Moderate**	**High**	**Very High**	**Not applicable**
Code Reviews						
Threat Modeling						
Identifying Abuse/Misuse Cases						
Architectural Risk Analysis						
Penetration Testing						
Risk Management						
Vulnerability Management						
Manual/Automated Security Testing						
Performing Fuzz Testing						
Security Requirements Engineering						
Secure Coding						
Emergency Codebase Response						
Security Configurations & Management						

Monitoring for Security Events						
Undergoing External Security Audits						
Software Supply Chain Security						

22) What is your opinion regarding the following statement as applied to each of the practices below: "This practice is essential for protecting the system." (Mandatory)

Practice	**Totally agree**	**Agree**	**Neutral**	**Disagree**	**Totally Disagree**	**Not applicable**
Code Reviews						
Threat Modeling						
Identifying Abuse/Misuse Cases						
Architectural Risk Analysis						
Penetration Testing						
Risk Management						
Vulnerability Management						
Manual/Automated Security Testing						
Performing Fuzz Testing						
Security Requirements Engineering						
Secure Coding						
Emergency Codebase Response						

Security Configurations & Management						
Monitoring for Security Events						
Undergoing External Security Audits						
Software Supply Chain Security						

ADOPTION OF AUTOMATED SECURITY TOOLS

In this section, we'll explore the adoption of automated software security tools and your experience using them.

To answer the following question, consider the categories of automated security tools below:

- **3rd Party Vulnerability Scanning:** refers to the verification of proper implementation and testing related to security risks and vulnerabilities in external components.
- **Static/Dynamic Application Security Testing Tools:** refers to testing the security vulnerabilities of product components and their dependencies to maintain an up-to-date security patch level.
- **Secure Configuration/Hardening Tools:** describes the process of applying security configuration measures to minimize the attack surface or ensure compliance with security standards.
- **Compliance/Hardening Checks Tools:** involves verifying if the configuration/hardening measures align with best practices.
- **Secrets Management Tools:** involves managing confidential information, such as passwords or private keys, as well as protection measures to prevent the leakage of sensitive information.

23) Do you often use automated security tools in your daily work? (Obrigatória)

( ) Yes
( ) Partially use
( ) I don't usually use

ADOPTION OF AUTOMATED SECURITY TOOLS

In this section, we'll explore the adoption of automated software security tools and your experience using them.

To answer the following question, consider the categories of automated security tools below:

- **3rd Party Vulnerability Scanning:** refers to the verification of proper implementation and testing related to security risks and vulnerabilities in external components.
- **Static/Dynamic Application Security Testing Tools:** refers to testing the security vulnerabilities of product components and their dependencies to maintain an up-to-date security patch level.
- **Secure Configuration/Hardening Tools:** describes the process of applying security configuration measures to minimize the attack surface or ensure compliance with security standards.
- **Compliance/Hardening Checks Tools:** involves verifying if the configuration/hardening measures align with best practices.
- **Secrets Management Tools:** involves managing confidential information, such as passwords or private keys, as well as protection measures to prevent the leakage of sensitive information.

24) **For each of the following categories of automated security tools, indicate how often you use them. Consider marking "Not Applicable" for categories of tools that you do not use. (Mandatory)**

Category	**Daily**	**Weekly**	**Monthly**	**Annually**	**Not applicable**
3rd Party Vulnerability Scanning Tools					
Static Application Security Testing Tools					
Dynamic Application Security Testing Tools					
Secure Configuration/Hardening Tools					
Compliance/Hardening Checks Tools					
Secrets Management Tools					

25) **Which of the following specific software security tools do you currently use or have used in the past? If none of the listed options apply, select "Other" and specify. (multiple choices allowed) (Mandatory)**

[ ] Dependabot
[ ] PHP Security Checker
[ ] Snyk
[ ] Clair
[ ] Blackduck
[ ] Retire.JS
[ ] SRC:CLR
[ ] Anchore
[ ] Node Security Platform
[ ] Trivy
[ ] Sonatype
[ ] Whitesource
[ ] CodeQL
[ ] CheckStyle
[ ] Coverity
[ ] SonarQube
[ ] Bandit
[ ] PHPStan
[ ] LGTM
[ ] Brakeman
[ ] Qark
[ ] ESLint Security
[ ] Dart Analyzer
[ ] Checkmarx
[ ] DevSkim
[ ] CFN NAG
[ ] SpotBugs
[ ] Chef
[ ] Ansible
[ ] Terraform
[ ] Puppet
[ ] Phan
[ ] Seccomp
[ ] CloudCustodian
[ ] Turbot
[ ] Bane
[ ] Ansible-Lint
[ ] Blackbox
[ ] Puppet-Lint
[ ] InSpec
[ ] Kube Audit
[ ] Foodcritic
[ ] Cookstyle
[ ] conftest

[ ] Pinterest Knox
[ ] GitLeaks
[ ] CyberArk Conjur
[ ] ThoughtWorks Talisman
[ ] Berglas
[ ] Docker Secrets
[ ] Trufflehog
[ ] AppScan
[ ] Fortify
[ ] Others:_____

26) In which phases of the software development lifecycle do you typically use the automated security tools selected in the previous question? (Select all options that apply) (Mandatory)

[ ] During coding
[ ] During Continuous Integration (CI)
[ ] During Continuous Delivery (CD)
[ ] During code review
[ ] During testing
[ ] In production

27) What recommendations would you give to a developer regarding the adoption of security tools for their projects? (Mandatory)

_____

_____

28) What are the main challenges you face when automating security tools? (Select all options that apply) (Mandatory)

[ ] Cost
[ ] Learning curve
[ ] Integration with other tools
[ ] System performance
[ ] False positives
[ ] False negatives
[ ] Maintenance of automated tools
[ ] Scalability
[ ] Lack of technical support
[ ] Compatibility with different development environments
[ ] Need for frequent updates
[ ] Adherence to standards and compliance
[ ] Lack of visibility or inadequate reporting
[ ] Others:_____

29) **What improvements would you like to see in the automated security tools you currently use? (Select all options that apply) (Mandatory)**
[ ] Increase the scope of threats
[ ] Fewer false positives
[ ] Better integration with CI/CD
[ ] Better documentation and support
[ ] Ease of use
[ ] Better interface usability
[ ] Reduced analysis time
[ ] Better compatibility with different development environments
[ ] More detailed and customizable reports
[ ] Others:_____

30) **If you would like to receive the results of this study and participate in a future interview on Software Security Practices, please provide your email address (Optional)**

_____

_____

ADOPTION OF AUTOMATED SECURITY TOOLS

In this section, we'll explore the adoption of automated software security tools and your experience using them.

31) **What are the reasons you choose not to use automated software security tools? Please briefly describe them. (Mandatory)**

_____

_____

32) **Do you consider using automated software security tools in your projects in the future? (Mandatory)**
( ) Yes
( ) No
( ) Maybe

33) **If you answered "Yes" or "Maybe" to the previous question, please indicate which tools you would use. Select "None" if you answered "No". If none of the listed options apply, select "Other" and specify. (Select all options that apply) (Mandatory)**
[ ] None
[ ] Dependabot
[ ] PHP Security Checker

[ ] Snyk
[ ] Clair
[ ] Blackduck
[ ] Retire.JS
[ ] SRC:CLR
[ ] Anchore
[ ] Node Security Platform
[ ] Trivy
[ ] Sonatype
[ ] Whitesource
[ ] CodeQL
[ ] CheckStyle
[ ] Coverity
[ ] SonarQube
[ ] Bandit
[ ] PHPStan
[ ] LGTM
[ ] Brakeman
[ ] Qark
[ ] ESLint Security
[ ] Dart Analyzer
[ ] Checkmarx
[ ] DevSkim
[ ] CFN NAG
[ ] SpotBugs
[ ] Chef
[ ] Ansible
[ ] Terraform
[ ] Puppet
[ ] Phan
[ ] Seccomp
[ ] CloudCustodian
[ ] Turbot
[ ] Bane
[ ] Ansible-Lint
[ ] Blackbox
[ ] Puppet-Lint
[ ] InSpec
[ ] Kube Audit
[ ] Foodcritic
[ ] Cookstyle
[ ] conftest
[ ] Pinterest Knox
[ ] GitLeaks

[ ] CyberArk Conjur
[ ] ThoughtWorks Talisman
[ ] Berglas
[ ] Docker Secrets
[ ] Trufflehog
[ ] AppScan
[ ] Fortify
[ ] Others:_____

34) If you would like to receive the results of this study and participate in a future interview on Software Security Practices, please provide your email address. (Opcional)

_____

_____

VALIDATION OF PARTICIPATION

In this section, we aim to confirm that you are a human participant.

35) Mark the image in which a puppy appears: (Mandatory)

( ) Option 1



( ) Option 2



( ) Option 3



( ) Option 4

